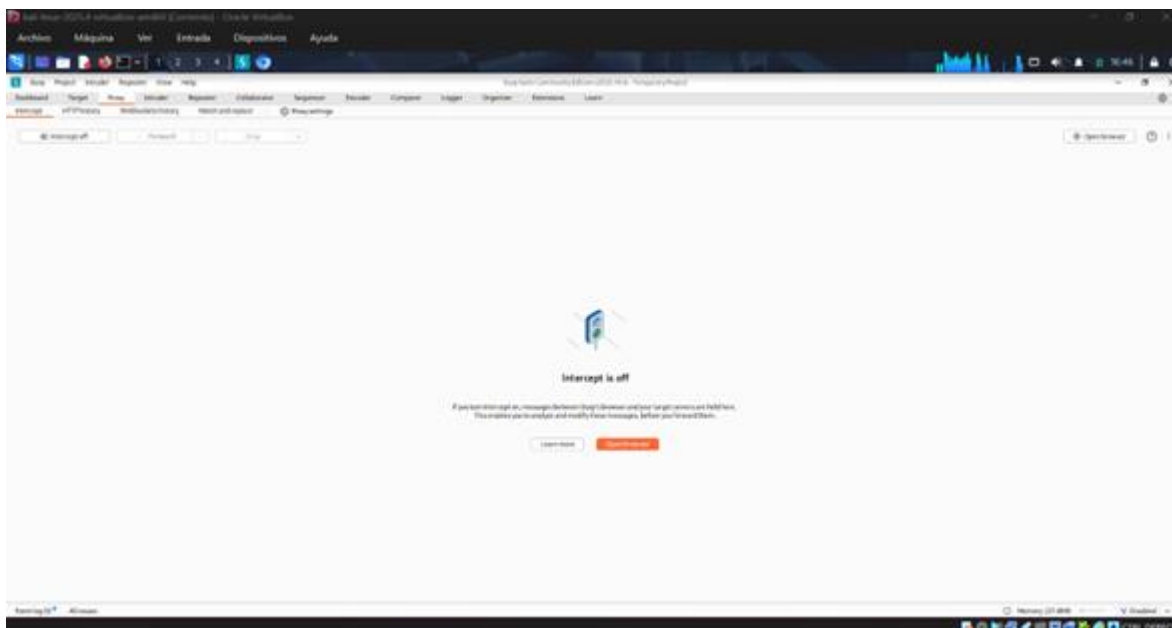


Pruebas a la página oficial de Colombia Comparte Con Burp Suit

Para complementar nuestro análisis de seguridad sobre el sitio de Colombia Comparte, utilizaremos Burp Suite dentro de nuestra máquina virtual de Kali Linux. A diferencia de los escaneos automáticos, Burp Suite nos permite actuar como un intermediario entre el navegador y el servidor, facilitando la interceptación, modificación y análisis detallado de cada paquete de datos para identificar fallos lógicos y vulnerabilidades críticas que un escaneo pasivo podría pasar por alto.

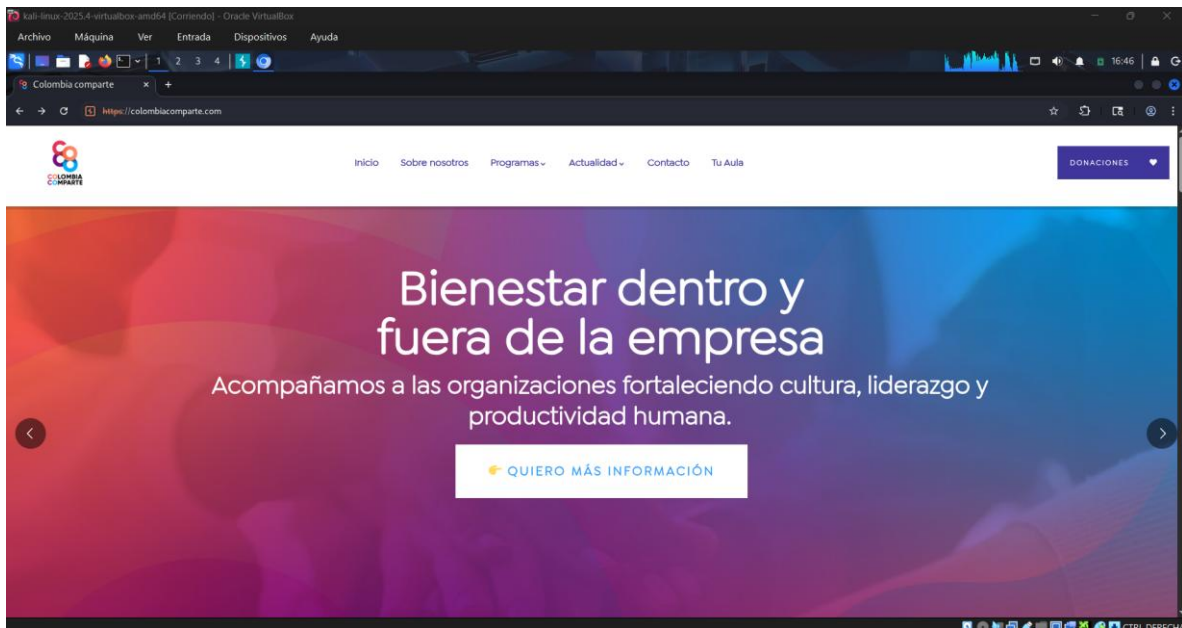
1. Inicialización y Configuración del Proxy

Iniciamos la herramienta Burp Suite dentro del entorno de Kali Linux. Tras la carga, nos dirigimos a la pestaña Proxy y verificamos el estado de la subpestaña Intercept



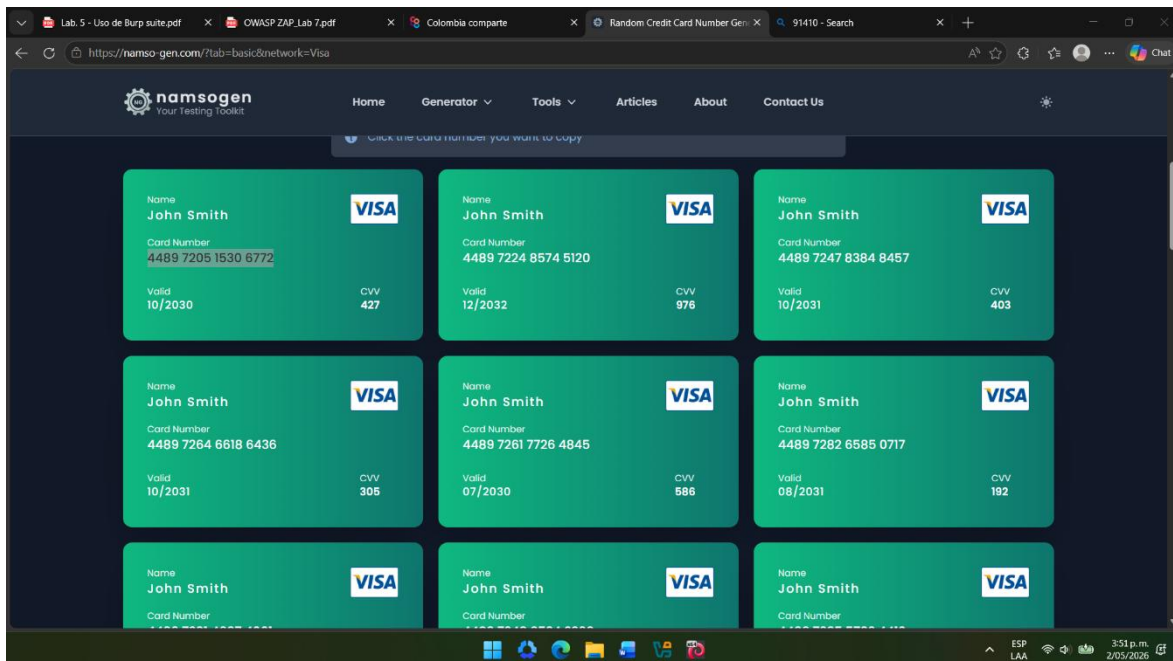
2. Acceso al Objetivo y Mapeo Inicial

Una vez iniciado el navegador integrado, ingresamos la URL del sitio oficial de Colombia Comparte en la barra de direcciones.



3. Generación de Datos Sintéticos para Pruebas de Entrada

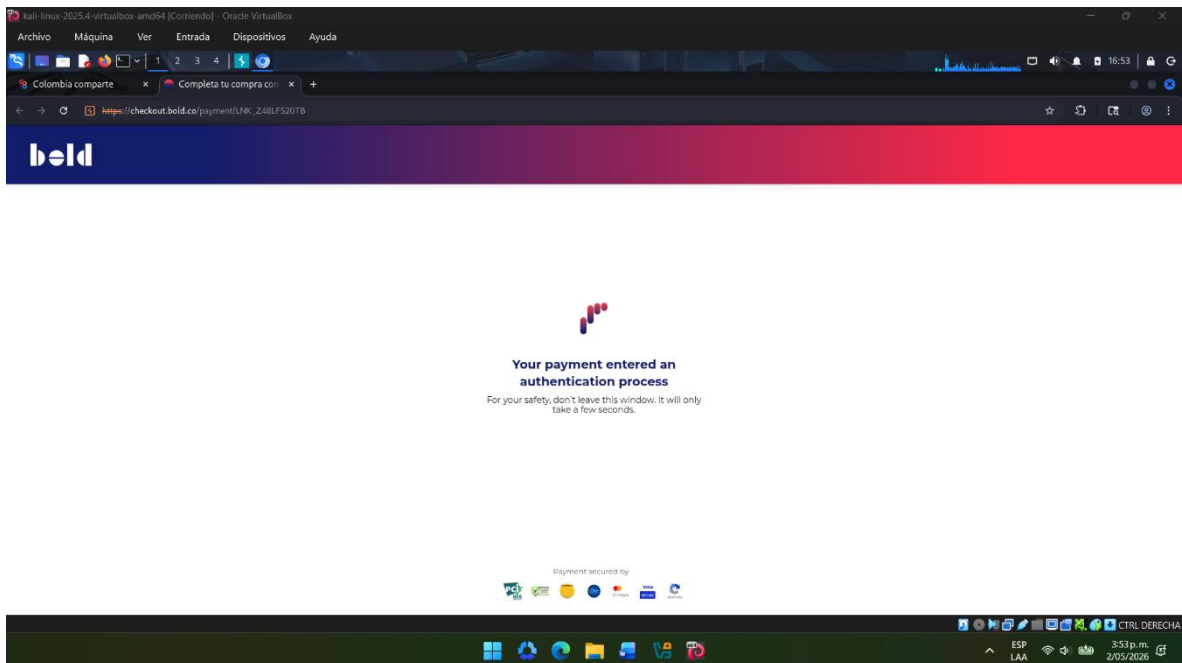
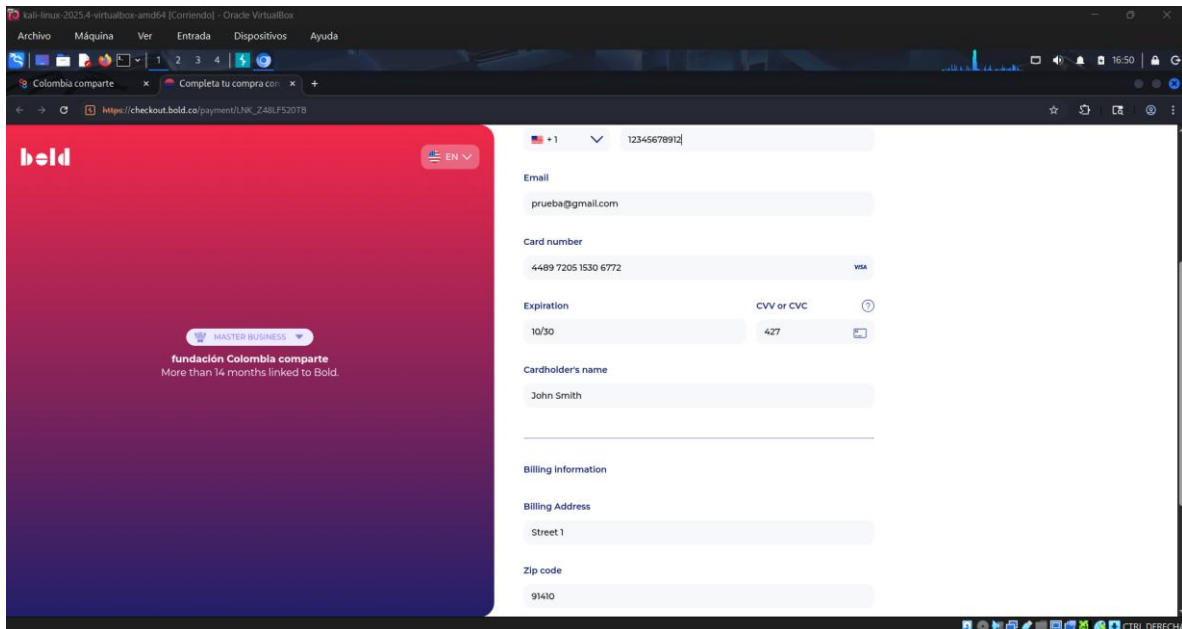
Para realizar pruebas de validación y manejo de datos financieros en los formularios del sitio, procedemos a generar información de prueba. Como se observa en la imagen, utilizamos la herramienta NamsoGen para obtener números de tarjeta de crédito ficticios.



4. Interceptación del Proceso de Pago mediante Proxy

Con los datos sintéticos generados, procedemos a completar el formulario de donación en la pasarela de pagos integrada en Colombia Comparte.

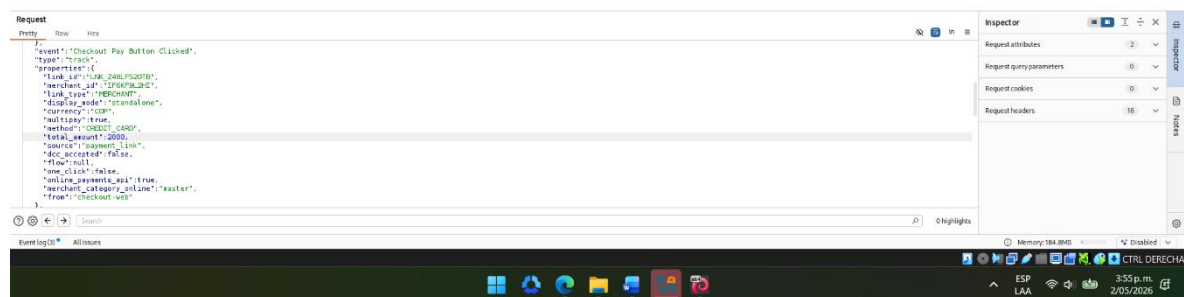
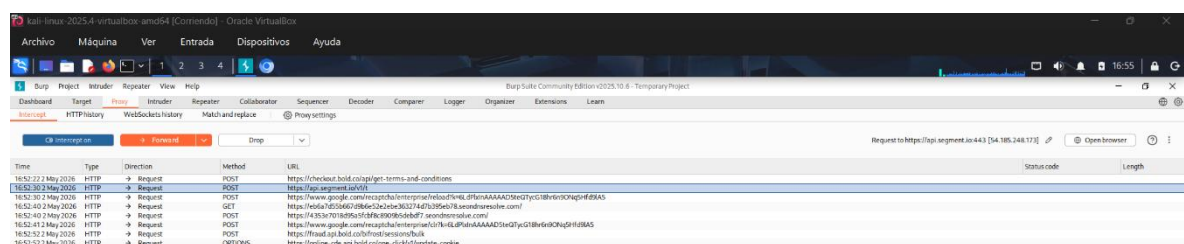
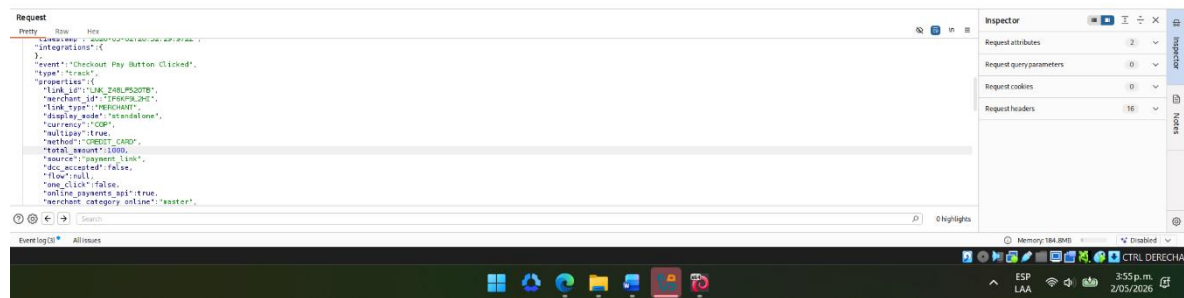
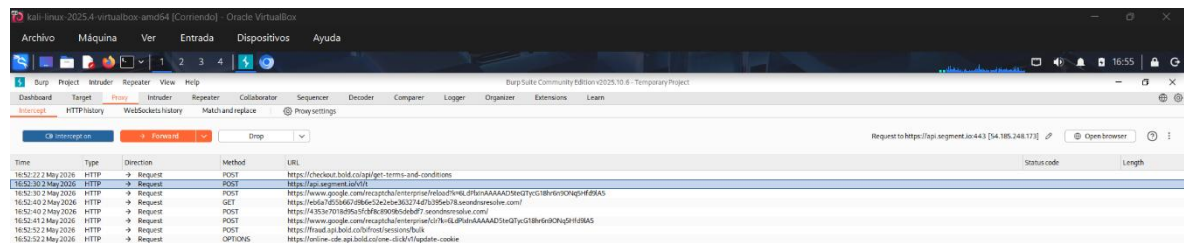
Antes de ejecutar la transacción, nos dirigimos a Burp Suite y activamos el botón "Intercept is on". Al dar clic en el botón de donar dentro del navegador, la petición HTTP no se envía directamente al servidor; en su lugar, queda atrapada en el proxy.



5. Manipulación de Parámetros en Tiempo Real (Tampering)

Una vez interceptada la petición de pago en la pestaña Proxy > Intercept, procedemos a realizar un análisis del cuerpo de la solicitud (Request Body). Localizamos el parámetro crítico de la transacción: "total_amount".

Tras realizar el cambio, presionamos el botón "Forward" para enviar la petición modificada al servidor. Este tipo de análisis permite identificar si existe una confianza ciega en los datos enviados por el cliente, lo cual es un riesgo crítico para la lógica de negocio de la plataforma de Colombia Comparte.



6. Ejecución y Análisis de Respuesta (Burp Repeater)

Tras realizar la modificación del parámetro "total_amount", enviamos la petición al módulo Repeater para procesar la solicitud de forma aislada y repetitiva. Como se observa en la imagen, al presionar el botón "Send", el servidor procesa la petición modificada y devuelve una respuesta en tiempo real.

The image displays two screenshots of the Burp Suite interface, specifically the Repeater tab, used for testing HTTP requests.

Top Screenshot: Shows the 'Request' tab with a POST request to `https://api.segment.io`. The request body is a JSON object containing event data for a 'Checkout Pay Button Clicked' event. The 'Send' button is highlighted, indicating the request is about to be sent.

Bottom Screenshot: Shows the 'Response' tab after the request has been sent. The response is a 200 OK status with a JSON body indicating success: `{\"success\":true}`. The 'Inspector' panel on the right shows the details of the response headers and body.

The interface includes a menu bar (File, Project, Intruder, Repeater, View, Help), a toolbar with buttons like 'Send', 'Cancel', and 'Burp AI', and a sidebar with tabs for 'Dashboard', 'Target', 'Proxy', 'Intruder', 'Repeater', 'Collaborator', 'Sequences', 'Decoder', 'Comparer', 'Logger', 'Organizer', 'Extensions', and 'Learn'.

El éxito de esta prueba demuestra que el sistema de Colombia Comparte confía en los valores numéricos enviados desde el cliente, permitiendo que un atacante modifique montos económicos. Se recomienda implementar una validación del lado del servidor que contraste el ID de la transacción con el monto original registrado en la base de datos antes de procesar el pago final.